

CYBERSECURITY THREAT MODEL AND PENETRATION TESTING ASSESSMENT
=====

1. Threat Landscape, STRIDE Modeling, and Attack Surface Mapping

This comprehensive cybersecurity assessment articulates the threat modeling results and penetration testing findings for our enterprise cloud ecosystem. The threat model utilizes the Microsoft STRIDE methodology: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege.

External attack surface mapping identified 142 exposed public endpoints, all protected by Web Application Firewalls (WAF) implementing OWASP Core Rule Sets. Rate limiting and bot management policies mitigate automated credential stuffing and brute-force authentication attacks.

Internal architecture models privilege boundaries between DMZ web tiers, application microservices, and database persistence layers, verifying that network segmentation prevents lateral movement in the event of an individual perimeter host compromise.

2. Cryptographic Implementation, KMS Key Rotations, and Data Protection

Data at rest is encrypted across all storage volumes, S3 buckets, and RDS database snapshots using AES-256-XTS and envelope encryption orchestrated by Hardware Security Modules (HSM) certified to FIPS 140-2 Level 3 standards.

KMS Customer Managed Keys (CMK) undergo automated annual cryptographic key rotations. Database columns containing sensitive PII and financial records are protected using application-level format-preserving encryption (FPE),

preventing database administrators from viewing plaintext records.

Data in transit mandates TLS 1.3 across all network interfaces, strictly prohibiting legacy SSLv3, TLS 1.0, and TLS 1.1 protocols. Perfect Forward Secrecy (PFS) using Ephemeral Elliptic Curve Diffie-Hellman (ECDHE) key exchange protects historical network traffic against retrospective decryption.

3. Penetration Testing Findings, Vulnerability Remediation, and Red Team Ops

Annual independent red team penetration testing evaluated the resilience of identity and access management (IAM), API endpoints, and cloud infrastructure. Testers identified zero Critical or High severity vulnerabilities across the external perimeter.

Medium-severity findings, including Cross-Origin Resource Sharing (CORS) wildcard misconfigurations on staging subdomains and verbose error trace disclosures, were remediated and verified within seven business days under strict SLA protocols.

Simulated spear-phishing campaigns conducted across internal workforce personnel achieved a 98.4% reporting rate, demonstrating high employee security awareness regarding social engineering tactics.

4. Incident Response Plan, SOC Operations, and Automated Threat Containment

The 24/7 Security Operations Center (SOC) utilizes an AI-assisted Security Information and Event Management (SIEM) platform ingesting over 50,000 security events per second from endpoints, cloud audit trails (CloudTrail), and VPC Flow Logs.

Automated Security Orchestration, Automation, and Response (SOAR) playbooks isolate compromised host instances, revoke active IAM credentials, and block suspicious IP ranges within sub-second response windows, containing potential intrusions before data exfiltration occurs.